Cheatsheet AZ-104 — 05 · Acceso a storage: claves, SAS, stored access policies e identidad para Azure Files

1. Las cuatro formas de autorizar

Método	Qué es	Alcance	Revocar	Señal
Shared Key (access keys)	Dos claves de 512 bits con **acceso total** a toda la cuenta (todos los servicios y datos)	Todo	Regenerar la clave	"full access", "connection string", "mount with account key"
SAS (shared access signature)	Token en la URL con permisos, recursos, ventana de tiempo, IP y protocolo	Lo que diga el token	Depende del tipo (sección 3)	"temporary access", "specific container", "partner without an account"
Microsoft Entra ID (RBAC de datos)	Roles con DataActions sobre blob, cola, tabla o Files	Según rol y ámbito (cuenta, contenedor)	Quitar la asignación	"most secure", "identity-based", "no keys in code"
Acceso anónimo	Contenedor con nivel Blob o Container, si la cuenta lo permite	Lectura pública	Cambiar el nivel / desactivar en la cuenta	"publicly readable images on a website"

Regla de oro del examen: cuando pregunten por "the most secure" o "least privilege" → **Entra ID** (managed identity para apps, user delegation SAS para compartir); claves y SAS firmadas con clave solo si el enunciado lo exige.

2. Access keys

- Dos claves (**key1 / key2**) para rotar sin corte: cambia las apps a key2, regenera key1, y al revés. Regenerar una clave **invalida todas las SAS firmadas con ella** (account y service SAS). Se puede fijar un **recordatorio de rotación** (p. ej. 90 días) y **Key Vault** puede gestionar y rotar las claves por ti.
- Quién las ve: necesita la acción `Microsoft.Storage/storageAccounts/listKeys/action` → Owner, Contributor, Storage Account Contributor, **Storage Account Key Operator Service Role** (solo listar y regenerar). **Reader no** (y un lock ReadOnly tampoco deja).
- **"Allow storage account key access" = Disabled** → se bloquean las claves y las SAS firmadas con clave; solo funcionan Entra ID y user delegation SAS. Azure Files por SMB con clave deja de montar. Azure Policy puede exigir este ajuste. Las apps que usan connection string fallan con 403.
- Connection string = `DefaultEndpointsProtocol=https;AccountName=st1;AccountKey=...` → es equivalente a dar la clave.

3. SAS: tres tipos

	Account SAS	Service SAS	User delegation SAS
Firmada con	Clave de la cuenta	Clave de la cuenta	**Credenciales de Entra ID** (user delegation key)
Alcance	Uno o varios **servicios** (blob, file, queue, table) y operaciones de nivel servicio (crear contenedores, propiedades)	**Un** recurso de **un** servicio: contenedor, blob, share, fichero, cola, tabla	Blob (contenedor o blob; también Data Lake) y, recientemente, cola, tabla y Files
Stored access policy	No	**Sí** (hasta **5** por contenedor / share / cola / tabla)	No
Duración	La que fijes (política de expiración recomendada)	La que fijes	Máximo **7 días**
Revocar	Regenerar la clave	Borrar o editar la **stored access policy**; si es ad hoc, regenerar clave	Revocar la user delegation key o quitar el rol del usuario
Permiso para crearla	Tener la clave	Tener la clave	Rol con `generateUserDelegationKey` (p. ej. **Storage Blob Delegator** o Storage Blob Data Contributor)
Señal	"access to multiple services", "create containers"	"share one blob / container", "revoke without regenerating keys" → + policy	"most secure", "no account key"

Parámetro	Significado
`sv`	Versión del servicio
`ss`	Servicios (account SAS): **b**lob, **f**ile, **q**ueue, **t**able
`srt`	Tipos de recurso (account SAS): **s**ervice, **c**ontainer, **o**bject
`sr`	Recurso (service SAS): b = blob, c = contenedor, s = share, f = fichero, d = directorio
`sp`	Permisos: **r**ead, **w**rite, **d**elete, **l**ist, **a**dd, **c**reate, **u**pdate, **p**rocess, **t**ags, **x** delete versions...
`st` / `se`	Inicio / **expiración** (UTC, formato ISO 8601)
`sip`	IP o rango permitido
`spr`	Protocolo: `https` (recomendado) o `https,http`
`si`	Identificador de la **stored access policy**
`sig`	Firma HMAC

- **Stored access policy:** se define en el contenedor (o share, cola, tabla) con permisos, inicio y fin; las service SAS que la referencian **heredan** esos límites. Cambiar la expiración o borrar la política revoca de golpe todas las SAS asociadas **sin regenerar claves**. Las account SAS y user delegation SAS no pueden usarla.

- Una SAS **no se puede auditar ni contar** (se genera en cliente). Buenas prácticas: HTTPS, caducidad corta, inicio 15 min en el pasado (clock skew), mínimo privilegio, **SAS expiration policy** en la cuenta (avisa si alguien crea una SAS más larga), plan de revocación.
- "SAS stopped working" → se regeneró la clave, caducó, hora del cliente desfasada, IP fuera de `sip`, HTTP con `spr=https`, o se desactivó el acceso con clave.

4. Entra ID y roles de datos

Servicio	Roles	Notas
Blob	**Storage Blob Data Owner** (todo + ACL de Data Lake) · **Data Contributor** (leer, escribir, borrar) · **Data Reader** · **Storage Blob Delegator** (crear user delegation key)	Ámbito: cuenta, contenedor; condiciones ABAC posibles
Queue	Storage Queue Data Contributor · Reader · **Message Processor** (leer y borrar) · **Message Sender** (añadir)	Para Functions / apps con MI
Table	Storage Table Data Contributor · Reader	—
Files (SMB)	**Storage File Data SMB Share Reader** · **Contributor** · **Elevated Contributor** (modifica ACL NTFS)	Permiso de **share**; dentro mandan las ACL de Windows
Files (REST / portal)	**Storage File Data Privileged Contributor / Reader**	Saltan las ACL; para operar desde el portal, PowerShell o AzCopy con Entra ID

- **Owner / Contributor no tienen acceso a datos** con Entra ID: el portal muestra "You do not have permissions" al abrir un contenedor con autenticación Entra; cambia a "Access key" o añade Storage Blob Data Reader. El toggle **"Default to Microsoft Entra authorization in the Azure portal"** fija el método por defecto.
- Para una **app o VM** → managed identity + rol de datos (nunca claves en código). Para un **usuario** → rol de datos en el contenedor justo.

5. Acceso anónimo a blobs

- Dos niveles: la **cuenta** debe tener "Allow Blob anonymous access" = Enabled (las cuentas nuevas lo traen **Disabled**) y el **contenedor** un nivel: **Private** (default), **Blob** (lectura de blobs si conoces la URL, sin listar) o **Container** (lectura y listado). "Public website images, no listing" → Blob. Por seguridad, Azure Policy puede prohibir el acceso anónimo.

6. Identidad para Azure Files (SMB)

Fuente de identidad	Requisitos	Para quién
On-premises AD DS	Unir la cuenta de storage al dominio (objeto de equipo o cuenta de servicio con `Join-AzStorageAccount`), usuarios **sincronizados** a Entra ID, clientes con línea de vista al **DC**	Migración de file servers; equipos unidos a AD DS
Microsoft Entra Domain Services	Habilitar en la cuenta; el dominio gestionado emite los tickets Kerberos	Lift-and-shift sin DCs propios; VMs unidas a Entra DS
Microsoft Entra Kerberos	Usuarios **híbridos** (sincronizados desde AD DS); clientes **Entra joined o hybrid joined**; no hace falta ver el DC para montar (sí para configurar ACL)	Teletrabajo, Windows 365 / AVD, sin VPN
Clave de la cuenta	Nada, pero es **superusuario**: ignora las ACL	Montaje inicial para poner ACL con `icacls`, scripts; no recomendado para usuarios

- Dos niveles de permiso: **share** (rol RBAC Storage File Data SMB Share * o un **permiso por defecto** para todos los usuarios autenticados) y **directorio / fichero** (ACL NTFS normales con icacls o el Explorador, tras montar con la clave).
- Red: SMB usa el puerto **445** con cifrado SMB 3.x; muchos ISP lo bloquean → montar desde on-prem exige **VPN / ExpressRoute + private endpoint**, o cachear con **Azure File Sync**. **NFS 4.1** (solo Premium) no usa identidades: solo control por red (VNet / private endpoint); cifrado en tránsito opcional con TLS (cliente AZNFS) y su propio ajuste "Require Encryption in Transit for NFS".
- Montar: Windows `net use Z: \\st1.file.core.windows.net\share1 /user:Azure\st1 <clave>` (o el script de "Connect" del portal); Linux `mount -t cifs //st1.file.core.windows.net/share1 /mnt/share1 -o username=st1,password=<clave>,serverino`. Con identidad, basta `net use` sin credenciales desde un equipo unido.

7. Comandos que caen

Tarea	PowerShell (Az.Storage)	Azure CLI
Regenerar clave	`New-AzStorageAccountKey -ResourceGroupName RG1 -Name st1 -KeyName key1`	`az storage account keys renew -n st1 -g RG1 --key primary`
Desactivar claves	`Set-AzStorageAccount -ResourceGroupName RG1 -Name st1 -AllowSharedKeyAccess $false`	`az storage account update -n st1 --allow-shared-key-access false`
Account SAS	`New-AzStorageAccountSASToken -Service Blob,File -ResourceType Service,Container,Object -Permission "rl" -ExpiryTime (Get-Date).AddDays(7) -Protocol HttpsOnly -Context $ctx`	`az storage account generate-sas --account-name st1 --services bf --resource-types sco --permissions rl --expiry 2026-12-31T00:00Z --https-only`
Service SAS	`New-AzStorageContainerSASToken -Name c1 -Permission rl -ExpiryTime ... -Context $ctx` · `New-AzStorageBlobSASToken -Container c1 -Blob f.txt -Permission r ...` · con policy: `-Policy p1`	`az storage container generate-sas -n c1 --permissions rl --expiry ... --account-name st1` · `az storage blob generate-sas` · con policy: `--policy-name p1`
User delegation SAS	`$ctx = New-AzStorageContext -StorageAccountName st1 -UseConnectedAccount` → `New-AzStorageContainerSASToken ... -Context $ctx` (genera user delegation SAS)	`az storage container generate-sas -n c1 --permissions r --expiry ... --auth-mode login --as-user`

Tarea	PowerShell (Az.Storage)	Azure CLI
Stored access policy	`New-AzStorageContainerStoredAccessPolicy -Container c1 -Policy p1 -Permission rl -ExpiryTime ...` · `Set-AzStorageContainerStoredAccessPolicy` · `Remove-...`	`az storage container policy create -c c1 -n p1 --permissions rl --expiry ...` · `update` · `delete`
Rol de datos	`New-AzRoleAssignment -SignInName ana@contoso.com -RoleDefinitionName "Storage Blob Data Reader" -Scope <id cuenta o contenedor>`	`az role assignment create --assignee ana@contoso.com --role "Storage Blob Data Reader" --scope <id>`
Acceso anónimo	`Set-AzStorageAccount ... -AllowBlobPublicAccess $true` · `Set-AzStorageContainerAcl -Name c1 -Permission Blob`	`az storage account update --allow-blob-public-access true` · `az storage container set-permission -n c1 --public-access blob`
Files con AD DS	`Join-AzStorageAccount -ResourceGroupName RG1 -StorageAccountName st1 -DomainAccountType ComputerAccount`	Entra Kerberos: `az storage account update -n st1 --enable-files-aadkerb true --domain-name contoso.com --domain-guid <guid>`

8. Árbol de decisión

```
¿Qué pide el enunciado?
├─ App en Azure accede a blobs sin secretos ........................... Managed identity + Storage Blob Data Contributor
├─ Usuario ve blobs en el portal con su cuenta ........................ Storage Blob Data Reader (Owner no basta)
├─ Compartir un blob con un externo unos días ......................... Service SAS (o user delegation SAS si piden "secure")
├─ Poder revocar sin regenerar claves ................................. Service SAS + stored access policy
├─ Acceso a varios servicios o crear contenedores ..................... Account SAS
├─ La SAS más segura, sin clave ....................................... User delegation SAS (máx. 7 días)
├─ Prohibir el uso de claves y SAS de clave ........................... Allow storage account key access = Disabled
├─ Rotar claves sin corte ............................................. Alternar key1 / key2 (o Key Vault)
├─ Imágenes públicas de una web ....................................... Cuenta con anonymous access + contenedor nivel Blob
├─ Share SMB con permisos de AD para equipos del dominio .............. Join al AD DS + roles SMB Share + ACL NTFS
├─ Share SMB para equipos Entra joined sin VPN ni DC .................. Entra Kerberos
├─ Share SMB sin DCs propios (lift and shift) ......................... Entra Domain Services
├─ Usuarios no pueden montar desde la oficina ......................... Puerto 445 cerrado → VPN/ER + private endpoint o File Sync
└─ NFS ................................................................ Premium + VNet / private endpoint (sin identidad)
```

9. Señales → respuesta

Enunciado	Respuesta
"most secure way for the app to access the storage account"	Managed identity + rol de datos
"Owner cannot browse the container in the portal"	Falta Storage Blob Data Reader (o usar la clave)
"generate a SAS that can be revoked without regenerating keys"	Service SAS + stored access policy
"SAS valid for 7 days, no storage key, Microsoft Entra"	User delegation SAS
"allow listing blobs in the container for a SAS"	Permiso `l` (list) en `sp`
"SAS must only work over HTTPS from the office IP"	`spr=https` + `sip`
"SAS works on one blob but fails to create containers"	Es service SAS: hace falta account SAS con `srt` = s,c
"after regenerating key1 the application fails"	Sus SAS / connection strings usaban key1 → rotar primero a key2
"prevent the use of shared keys"	Allow storage account key access = Disabled (y Policy para auditarlo)
"images must be publicly readable but not listable"	Container public access = Blob
"anonymous access option is greyed out"	La cuenta tiene "Allow Blob anonymous access" en Disabled
"file share with NTFS permissions for domain users"	Identidad AD DS + Storage File Data SMB Share Contributor + icacls
"users must access the share from Entra joined devices over the internet"	Entra Kerberos
"mount fails with error 53 / 67 from on-premises"	Puerto 445 bloqueado
"set NTFS ACLs on the share"	Montar con la **clave** (superusuario) o rol Elevated Contributor
"copy files to the share with AzCopy from the portal/REST using identity"	Storage File Data Privileged Contributor
"Storage Account Key Operator Service Role"	Solo listar y regenerar claves (mínimo privilegio para rotación)

10. Errores a evitar

1. Dar la clave de la cuenta (o la connection string) cuando piden acceso temporal o acotado: eso es una SAS.
2. Creer que una SAS ad hoc firmada con clave se puede revocar sin regenerar la clave.
3. Asociar una stored access policy a una account SAS o a una user delegation SAS: solo a service SAS.
4. Pedir una user delegation SAS de 30 días: el máximo es 7.
5. Pensar que Owner o Contributor leen blobs con Entra ID: hacen falta roles de **datos**.
6. Olvidar que regenerar una clave rompe las SAS firmadas con ella y las apps con connection string.
7. Poner acceso anónimo en el contenedor sin habilitarlo primero en la cuenta.
8. Elegir Entra Domain Services cuando los usuarios y equipos ya están en AD DS (y al revés), o Entra Kerberos para usuarios **solo cloud** (necesita identidades híbridas).
9. Intentar montar SMB desde casa sin VPN: el 445 suele estar bloqueado.